

Wireless Attacks & Security

Wireless = the new front door

Wi-Fi is wireless, un-walled, and ubiquitous; SOHO routers ship insecure by default. It's also the fastest entry vector for real-world compromises.

Attack catalog (and its fixes)

Attack	How	Defense
Evil twin	Clone SSID at high signal; captive portal steals creds	WPA3/WPA2-enterprise w/ certs; user skepticism; WIPS
Captive portal phishing	Cloned login page + deauth of legit AP	unique SSIDs, EAP-TLS, training
Deauth / DoS	aireplay-ng flood kills clients	deauth detection on WIPS
WPS PIN brute	Reaver/airgeddon	disable WPS
WPA2 handshake crack	aircrack the 4-way	strong passphrase + WPA3 (no handshake crack); 802.1X
KRACK / Dragonblood	WPA2/WPA3 protocol bugs	patch AP/firmware; WPA3 transitional
Rogue AP / pineapple	extra 'friendly' AP=sniffer	802.1X + WIPS/monitoring

Enterprise wireless: the real solution

WPA2-Enterprise / WPA3-Enterprise + RADIUS + 802.1X EAP-TLS:

- Each client gets a cert; password-only EAP-PEAP (MSCHAPv2) also cracked via hash attacks – prefer EAP-TLS (cert-only)

- MAB (MAC Auth Bypass) for printers → still a hole
- NPS/RADIUS sends authentication to AAA; logs every session

WIPS (Wireless IPS)

Probes the air for: rogue APs, evil twins, deauth storms, mis-assoc. Plus RF monitoring. Enterprise-grade WIPS (or at minimum a periodic **Wi-Fi scanner** like Kismet) is your '802.11 IDS'.

Behavior you learn as the defender

Inventory your SSID + neighbors (visual Wifi-scan)

Know your SSID's MAC – evil twin disguises name not always BSSID

Method = your SSID uses WPA3 with PMF (protection management frames)
→ response to deauth storms

If a box can't do WPA2/WPA3/802.1X → it shouldn't be on the enterprise network

On the airwaves, identity is everything. The certificate you hold decides whether you're you.

[← DHCP Abuses & DNS Tunneling](#)

[Egress Abuse, DoS & Lateral Pa...](#)